# Corrigé commenté · Module 4

La bonne réponse est surlignée en **fluo**. À droite, une courte note explique le raisonnement.

## Récapitulatif rapide

| | | | | | | | |
|---|---|---|---|---|---|---|---|
| 1 → C | 2 → C | 3 → A | 4 → A | 5 → C | 6 → A | 7 → C | 8 → B |
| 9 → A | 10 → D | 11 → B | 12 → A | 13 → C | 14 → B | 15 → D | 16 → C |
| 17 → D | 18 → A | 19 → C | 20 → B+D | 21 → B | 22 → B | 23 → C | 24 → A |
| 25 → A | 26 → A | 27 → B | 28 → B | 29 → D | 30 → D | 31 → A | 32 → A |
| 33 → B | 34 → D | 35 → B | 36 → B | 37 → C | 38 → C | 39 → B | 40 → C |

## Barème indicatif

| Score | Interprétation |
|---|---|
| 36 à 40 | Excellent : vous maîtrisez le module, passez au module suivant. |
| 30 à 35 (≥ 75 %) | Bon niveau : revoyez les questions manquées et les nuances (refus implicite/explicite, rôle/utilisateur, rôle des services de sécurité). |
| 24 à 29 | À consolider : relisez le module 4 et refaites le QCM dans quelques jours. |
| moins de 24 | Reprenez le cours depuis le début, en dessinant le schéma de la responsabilité partagée. |

# Partie 1 : Niveau facile

## Question 1

FACILE



Resp. partagée

**Dans le modèle de responsabilité partagée, de quoi AWS est-il responsable ?**

**A.** De la sécurité VERS le cloud
**B.** De la gestion des mots de passe des utilisateurs du client
**C.** **De la sécurité DU cloud** ✔
**D.** De la sécurité DANS le cloud

**EXPLICATION**
**Réponse : C**
AWS = sécurité DU cloud (bâtiments, matériel, réseau, logiciel d'infrastructure). Le client = sécurité DANS le cloud (données, accès, configuration).

## Question 2

FACILE



Resp. partagée

**Parmi ces tâches, laquelle incombe toujours au client ?**

**A.** La sécurité physique des data centers
**B.** Le remplacement des disques défaillants
**C.** **La gestion de ses données et des accès à ses ressources (IAM)** ✔
**D.** La maintenance du matériel réseau d'AWS

**EXPLICATION**
**Réponse : C**
Les données, la gestion des identités et des permissions restent toujours à la charge du client, quel que soit le service utilisé.

## Question 3

FACILE



IAM

**Quel service permet de contrôler qui peut accéder aux ressources AWS et avec quelles permissions ?**

**A.** **AWS IAM** ✔
**B.** Amazon Route 53
**C.** AWS Snowball
**D.** Amazon CloudFront

**EXPLICATION**
**Réponse : A**
AWS Identity and Access Management (IAM) gère utilisateurs, groupes, rôles et politiques. C'est un service global.

## Question 4 FACILE



MFA

**Quelle fonctionnalité ajoute une seconde vérification (par exemple un code à usage unique) lors de la connexion à un compte AWS ?**

**A.** **L'authentification multifacteur (MFA)** ✓
**B.** Le pare-feu applicatif
**C.** Le chiffrement des données
**D.** Les groupes de sécurité

**EXPLICATION**
**Réponse : A**
La MFA combine quelque chose que l'on connaît (mot de passe) et quelque chose que l'on possède (application, clé de sécurité, jeton).

## Question 5 FACILE


Utilisateur

**Quelle identité a un accès complet à toutes les ressources du compte et ne devrait pas être utilisée pour les tâches courantes ?**

**A.** Un rôle IAM
**B.** Un groupe IAM
**C.** **L'utilisateur racine (root) du compte** ✓
**D.** Un utilisateur IAM administrateur

**EXPLICATION**
**Réponse : C**
L'utilisateur racine est créé avec le compte. Protégez-le avec la MFA et servez-vous d'un utilisateur IAM pour le quotidien.

## Question 6 FACILE


Artifact

**Quel service donne un accès à la demande aux rapports de conformité d'AWS (par exemple SOC, ISO, PCI) ?**

**A.** **AWS Artifact** ✓
**B.** Amazon CloudWatch
**C.** AWS Trusted Advisor
**D.** AWS Direct Connect

**EXPLICATION**
**Réponse : A**
AWS Artifact est le portail libre-service des rapports d'audit et des accords (par exemple BAA) d'AWS.

## Partie 2 : Niveau moyen

### Question 7 MOYEN


Groupe IAM

**Qu'est-ce qu'un groupe IAM ?**

**A.** Un ensemble de Régions autorisées pour un compte
**B.** Un ensemble de comptes AWS regroupés pour la facturation
**C.** **Un ensemble d'utilisateurs IAM auxquels on attache des permissions communes** ✔
**D.** Un rôle que plusieurs services peuvent assumer

**EXPLICATION**
**Réponse : C**
Les groupes simplifient l'attribution des permissions : on attache une politique au groupe, tous ses membres en bénéficient.

### Question 8 MOYEN


Utilisateur


Rôle IAM

**Quelle est la principale différence entre un utilisateur IAM et un rôle IAM ?**

**A.** Un rôle ne peut avoir aucune politique de permissions
**B.** **Un rôle n'a pas d'identifiants permanents : il est assumé temporairement par une identité, un service ou une application** ✔
**C.** Un utilisateur IAM ne peut utiliser que la CLI
**D.** Un rôle est toujours réservé à l'utilisateur racine

**EXPLICATION**
**Réponse : B**
Un rôle fournit des identifiants temporaires (via STS) à qui l'assume ; un utilisateur IAM possède des identifiants à long terme.

### Question 9 MOYEN


Politique

**Qu'est-ce qu'une politique IAM ?**

**A.** **Un document JSON qui définit des permissions (actions autorisées ou refusées sur des ressources)** ✔
**B.** Un contrat de niveau de service avec AWS
**C.** Un rapport de conformité téléchargeable
**D.** Un type de clé de chiffrement

**EXPLICATION**
**Réponse : A**
Une politique est un document JSON avec des instructions Effect (Allow/Deny), Action et Resource.

## Question 10 MOYEN


Clé d'accès

**Quels identifiants permettent à l'AWS CLI ou à un SDK d'appeler les API AWS ?**

**A.** L'identifiant du compte à 12 chiffres
**B.** Le code MFA affiché sur le téléphone
**C.** Le mot de passe de connexion à la console
**D.** **Les clés d'accès (ID de clé d'accès et clé d'accès secrète)** ✔

**EXPLICATION**
**Réponse : D**
Les clés d'accès servent à l'accès programmatique. Le mot de passe sert à la console web.

## Question 11 MOYEN


EC2

**Vous exécutez une application sur une instance Amazon EC2. Quelle tâche vous incombe ?**

**A.** Mettre à jour le logiciel de l'hyperviseur
**B.** **Appliquer les correctifs du système d'exploitation invité** ✔
**C.** Assurer la sécurité physique du serveur
**D.** Remplacer le matériel défectueux

**EXPLICATION**
**Réponse : B**
EC2 est un service d'infrastructure : AWS gère le matériel et l'hyperviseur, le client gère l'OS invité, les applications, le pare-feu et les données.

## Question 12 MOYEN


KMS

**Quel service permet de créer et de contrôler les clés de chiffrement utilisées pour protéger vos données ?**

**A.** **AWS Key Management Service (AWS KMS)** ✔
**B.** Amazon Macie
**C.** AWS Shield
**D.** AWS Config

**EXPLICATION**
**Réponse : A**
KMS crée et gère les clés cryptographiques, s'intègre à de nombreux services (S3, EBS, RDS) et journalise leur usage dans CloudTrail.

## Question 13 MOYEN




**Quel service protège automatiquement contre les attaques DDoS courantes, sans coût supplémentaire pour tous les clients ?**

**A.** AWS WAF
**B.** AWS Secrets Manager
**C.** **AWS Shield Standard ✔**
**D.** Amazon GuardDuty

**EXPLICATION**
**Réponse : C**
Shield Standard est activé automatiquement et gratuitement. Shield Advanced est une offre payante avec protections étendues et assistance.

## Question 14 MOYEN




**Quel service enregistre les appels d'API effectués dans votre compte (qui, quoi, quand, depuis où) ?**

**A.** AWS Artifact
**B.** **AWS CloudTrail ✔**
**C.** AWS Trusted Advisor
**D.** Amazon CloudWatch

**EXPLICATION**
**Réponse : B**
CloudTrail = journal d'audit des actions sur le compte. CloudWatch = métriques, journaux applicatifs et alarmes.

## Question 15 MOYEN




**Quel service analyse automatiquement vos charges de travail (par exemple des instances EC2) pour y détecter des vulnérabilités logicielles ?**

**A.** AWS Organizations
**B.** Amazon Cognito
**C.** AWS Shield
**D.** **Amazon Inspector ✔**

**EXPLICATION**
**Réponse : D**
Amazon Inspector recherche vulnérabilités connues et expositions réseau involontaires, puis classe les résultats par priorité.

## Partie 3 : Niveau difficile

### Question 16 DIFFICILE


RDS


Resp. partagée

**Une société utilise Amazon RDS for MySQL. Laquelle de ces tâches reste à sa charge ?**

**A.** Appliquer les correctifs du système d'exploitation hôte
**B.** Remplacer le matériel du serveur de base de données
**C.** **Configurer les groupes de sécurité et gérer qui peut accéder aux données** ✓
**D.** Assurer la sécurité physique du data center

**EXPLICATION**
**Réponse : C**
RDS est un service géré : AWS gère matériel, OS et logiciel du moteur. Le client gère les données, l'accès réseau (groupes de sécurité), les utilisateurs et les paramètres de chiffrement.

### Question 17 DIFFICILE


Lambda


Resp. partagée

**Pour une fonction AWS Lambda, qui maintient le système d'exploitation et l'environnement d'exécution sous-jacents ?**

**A.** Le client, à chaque déploiement
**B.** Le client, seulement pour les fonctions de plus de 512 Mo
**C.** Le client et AWS à parts égales
**D.** **AWS ; le client reste responsable de son code, de ses données et des permissions IAM de la fonction** ✓

**EXPLICATION**
**Réponse : D**
Lambda est un service « abstrait » : AWS gère l'infrastructure et la plateforme d'exécution. Le client gère le code, les données et les permissions.

## Question 18 DIFFICILE


Resp. partagée

**Comment AWS qualifie-t-il la gestion des correctifs (patch management) dans le modèle de responsabilité partagée ?**

**A.** **Un contrôle partagé : AWS corrige l'infrastructure, le client corrige ses systèmes invités et ses applications** ✔
**B.** Un contrôle exclusivement à la charge d'AWS
**C.** Un contrôle exclusivement à la charge du client
**D.** Un contrôle hérité : le client en hérite entièrement

**EXPLICATION**
**Réponse : A**
Contrôles partagés : correctifs, gestion de la configuration, sensibilisation et formation. Contrôles hérités : par exemple la sécurité physique.

## Question 19 DIFFICILE


Utilisateur

**Quelle tâche exige obligatoirement les identifiants de l'utilisateur racine ?**

**A.** Créer un bucket Amazon S3
**B.** Lancer une instance EC2
**C.** **Fermer le compte AWS** ✔
**D.** Créer un utilisateur IAM

**EXPLICATION**
**Réponse : C**
Fermer le compte, changer le plan de support ou certains paramètres de compte nécessitent l'utilisateur racine. Le reste se fait avec un utilisateur IAM.

## Question 20 DIFFICILE


Utilisateur



MFA

**Quelles DEUX actions sont recommandées pour sécuriser un nouveau compte AWS ? (Choisissez deux réponses.)**

**A.** Partager le mot de passe racine avec toute l'équipe d'administration
**B.** **Activer la MFA sur l'utilisateur racine** ✔
**C.** Créer des clés d'accès pour l'utilisateur racine et les intégrer aux scripts
**D.** **Créer un utilisateur IAM administrateur et l'utiliser pour le travail quotidien** ✔
**E.** Désactiver la journalisation CloudTrail pour réduire les coûts

**EXPLICATION**
**Réponse : B+D**
Bonnes pratiques : MFA sur le root, ne pas créer de clés d'accès racine, utiliser un utilisateur IAM, appliquer le moindre privilège.

## Question 21 DIFFICILE






**Un utilisateur IAM appartient à deux groupes : l'un autorise s3:*, l'autre refuse explicitement s3:DeleteObject. Peut-il supprimer un objet S3 ?**

**A.** Oui, car le dernier groupe créé l'emporte
**B.** **Non, car un refus explicite l'emporte toujours sur une autorisation ✔**
**C.** Oui, car l'autorisation s3:* est plus large
**D.** Cela dépend de l'ordre alphabétique des groupes

**EXPLICATION**
**Réponse : B**
Évaluation IAM : refus par défaut, un Allow explicite autorise, mais un Deny explicite prime sur tout.

## Question 22 DIFFICILE




**Un nouvel utilisateur IAM est créé, sans aucune politique attachée. Que peut-il faire ?**

**A.** Tout, sauf accéder à la facturation
**B.** **Rien : l'accès est refusé par défaut (refus implicite) ✔**
**C.** Lire les ressources du compte, sans pouvoir les modifier
**D.** Accéder uniquement à Amazon S3

**EXPLICATION**
**Réponse : B**
Un utilisateur IAM n'a aucune permission tant qu'on ne lui en accorde pas. C'est la base du principe du moindre privilège.

## Question 23 DIFFICILE






**Une application sur Amazon EC2 doit lire des objets dans un bucket S3. Quelle est la bonne pratique ?**

**A.** Intégrer des clés d'accès IAM dans le code de l'application
**B.** Utiliser les clés d'accès de l'utilisateur racine dans une variable d'environnement
**C.** **Attacher à l'instance un rôle IAM avec les permissions nécessaires (profil d'instance) ✔**
**D.** Stocker les clés d'accès dans un fichier texte sur l'instance

**EXPLICATION**
**Réponse : C**
Le rôle fournit des identifiants temporaires, renouvelés automatiquement, sans secret à stocker ni à faire tourner à la main.

## Question 24 DIFFICILE



À identifier

**Le compte A veut donner accès à certaines ressources au compte B d'un partenaire, sans créer d'utilisateurs IAM pour lui dans le compte A. Quelle approche convient ?**

**A.** **Créer dans le compte A un rôle IAM que le compte B est autorisé à assumer** ✔
**B.** Partager les clés d'accès de l'utilisateur racine du compte A
**C.** Désactiver la MFA pour faciliter l'accès
**D.** Créer un utilisateur IAM avec le même nom dans chaque compte

**EXPLICATION**
**Réponse : A**
L'accès inter-comptes repose sur les rôles : le compte de confiance assume le rôle et obtient des identifiants temporaires.

## Question 25 DIFFICILE


Groupe IAM

**Quelle affirmation sur les groupes IAM est exacte ?**

**A.** **Un groupe contient uniquement des utilisateurs (pas d'autres groupes), et un utilisateur peut appartenir à plusieurs groupes** ✔
**B.** Un groupe peut contenir d'autres groupes
**C.** Un utilisateur ne peut appartenir qu'à un seul groupe
**D.** Un groupe peut être assumé comme un rôle

**EXPLICATION**
**Réponse : A**
Pas d'imbrication de groupes. Un groupe n'est pas une identité utilisable pour se connecter ; il sert uniquement à attribuer des permissions.

## Question 26 DIFFICILE


Clé d'accès

**Vous avez perdu la clé d'accès secrète d'un utilisateur IAM créée il y a un mois. Que faire ?**

**A.** **Créer une nouvelle clé, mettre à jour les applications, puis désactiver et supprimer l'ancienne ✔**

**B.** La consulter dans la console IAM

**C.** Demander son affichage au support AWS

**D.** Utiliser uniquement l'ID de clé d'accès, qui suffit à s'authentifier

**EXPLICATION**

**Réponse : A**

La clé secrète n'est visible qu'à la création. Si elle est perdue, on la remplace (rotation) et on désactive l'ancienne.

## Question 27 DIFFICILE


Organizations


Utilisateur

**Une stratégie de contrôle des services (SCP) d'AWS Organizations refuse l'accès à un service pour une unité d'organisation. Qu'advient-il de l'utilisateur racine d'un compte membre de cette unité ?**

**A.** Seuls les utilisateurs IAM sont restreints

**B.** **Il est également restreint par la SCP ✔**

**C.** La SCP s'applique uniquement aux rôles

**D.** Il n'est pas affecté, car le root contourne toujours les SCP

**EXPLICATION**

**Réponse : B**

Les SCP s'appliquent à tous les utilisateurs et rôles des comptes membres, y compris leur utilisateur racine (mais pas au compte de gestion).

## Question 28 DIFFICILE


Organizations


Politique

**Une SCP autorise ec2:* pour un compte membre. Un utilisateur IAM de ce compte, sans aucune politique IAM, peut-il lancer une instance EC2 ?**

**A.** Oui, mais uniquement dans la Région par défaut

**B.** **Non : une SCP ne donne pas de permissions, elle définit seulement le plafond de ce qui peut être autorisé ✔**

**C.** Oui, la SCP lui accorde cette permission

**D.** Oui, si l'utilisateur active la MFA

**EXPLICATION**

**Réponse : B**

Permissions effectives = intersection entre la SCP (plafond) et les politiques IAM (autorisations réelles). Sans politique IAM : refus.

## Question 29 DIFFICILE



À identifier

**Un auditeur veut savoir QUI a supprimé un groupe de sécurité hier à 14 h, ainsi que l'adresse IP source de l'appel d'API. Quel service consulter ?**

**A.** Amazon CloudWatch

**B.** AWS Trusted Advisor

**C.** Amazon Inspector

**D.** **AWS CloudTrail ✔**

**EXPLICATION**

**Réponse : D**

CloudTrail journalise l'identité, l'heure, l'IP source et les paramètres de chaque appel d'API.

## Question 30 DIFFICILE



À identifier

**Une équipe veut vérifier en continu que tous les volumes EBS sont chiffrés et conserver l'historique des changements de configuration des ressources. Quel service convient ?**

**A.** AWS CloudTrail
**B.** Amazon GuardDuty
**C.** AWS Artifact
**D.** **AWS Config** ✔

**EXPLICATION**
**Réponse : D**
AWS Config évalue la conformité des ressources à des règles et conserve l'historique des configurations.

## Question 31 DIFFICILE



À identifier

**Quel service analyse en continu les journaux CloudTrail, les journaux de flux VPC et les journaux DNS pour détecter des activités suspectes (par exemple une instance contactant une IP malveillante) ?**

**A.** **Amazon GuardDuty** ✔
**B.** AWS WAF
**C.** AWS KMS
**D.** AWS Shield Standard

**EXPLICATION**
**Réponse : A**
GuardDuty est un service de détection de menaces (intelligence des menaces et apprentissage automatique) activable en quelques clics.

## Question 32 DIFFICILE



À identifier

**Une société veut découvrir automatiquement les données personnelles (PII) stockées dans ses buckets S3, grâce à l'apprentissage automatique. Quel service ?**

**A.** **Amazon Macie** ✔
**B.** AWS Certificate Manager
**C.** Amazon Inspector
**D.** AWS CloudHSM

**EXPLICATION**
**Réponse : A**
Amazon Macie identifie et classe les données sensibles dans S3 et alerte en cas d'exposition à risque.

## Question 33 DIFFICILE


CloudFront

**Une application web distribuée via CloudFront subit des tentatives d'injection SQL. Quel service permet de filtrer ces requêtes HTTP malveillantes ?**

**A.** AWS KMS
**B.** **AWS WAF** ✔
**C.** Amazon GuardDuty
**D.** AWS Shield Standard

**EXPLICATION**
**Réponse : B**
AWS WAF filtre le trafic applicatif (couche 7) : injection SQL, XSS, limitation de débit. Shield Standard protège surtout contre les DDoS réseau/transport.

## Question 34 DIFFICILE



À identifier

**Une société exige un module de sécurité matériel dédié, à locataire unique, dont elle seule contrôle les clés cryptographiques. Quel service choisir ?**

**A.** Amazon Cognito
**B.** AWS Secrets Manager
**C.** Amazon Macie
**D.** **AWS CloudHSM** ✔

**EXPLICATION**
**Réponse : D**
CloudHSM fournit des HSM dédiés dans votre VPC, contrôlés par le client. KMS est un service géré par AWS avec un modèle multi-clients.

## Question 35 DIFFICILE



À identifier

**Quel service permet de provisionner, gérer et renouveler des certificats SSL/TLS pour chiffrer les données en transit ?**

**A.** AWS Artifact
**B.** **AWS Certificate Manager (ACM)** ✔
**C.** AWS Key Management Service
**D.** Amazon Inspector

**EXPLICATION**
**Réponse : B**
ACM gère les certificats TLS utilisés par exemple avec CloudFront et Elastic Load Balancing, avec renouvellement automatique.

## Question 36 DIFFICILE


S3

**Un bucket S3 a été exposé publiquement par erreur. Quelle fonctionnalité aide à empêcher tout accès public, au niveau du bucket ou de tout le compte ?**

**A.** S3 Transfer Acceleration
**B.** **S3 Block Public Access** ✔
**C.** Le versioning S3
**D.** Les classes de stockage S3 Glacier

**EXPLICATION**
**Réponse : B**
S3 Block Public Access neutralise les ACL et politiques publiques. Elle fait partie de la sécurisation des données dans S3.

## Question 37 DIFFICILE



À identifier

**Quel service signale, avec ses vérifications de base, qu'un groupe de sécurité laisse un port sensible ouvert à tout Internet ou que la MFA n'est pas activée sur le compte racine ?**

**A.** AWS Cost Explorer
**B.** AWS Artifact
**C.** **AWS Trusted Advisor** ✔
**D.** Amazon CloudFront

**EXPLICATION**
**Réponse : C**
Trusted Advisor inspecte le compte et émet des recommandations (coûts, performance, sécurité, tolérance aux pannes). Les contrôles de sécurité de base sont inclus pour tous.

## Question 38 DIFFICILE



À identifier

**Une application doit récupérer des identifiants de base de données qui changent automatiquement tous les 30 jours, sans redéployer le code. Quel service convient ?**

**A.** AWS Config
**B.** Amazon Cognito
**C.** **AWS Secrets Manager ✔**
**D.** AWS Shield

**EXPLICATION**
**Réponse : C**
Secrets Manager stocke, chiffre et fait tourner automatiquement les secrets (identifiants de base de données, clés d'API).

## Question 39 DIFFICILE



À identifier

**Une application mobile grand public doit proposer inscription et connexion à ses utilisateurs finaux, y compris via des fournisseurs d'identité sociaux. Quel service ?**

**A.** AWS Organizations
**B.** **Amazon Cognito ✔**
**C.** Amazon Inspector
**D.** AWS IAM (création d'un utilisateur IAM par client)

**EXPLICATION**
**Réponse : B**
Cognito gère l'authentification des utilisateurs d'applications (pools d'utilisateurs, fédération). IAM sert aux identités de votre personnel et de vos services.

## Question 40 DIFFICILE


Shield

**Selon la politique d'AWS sur les tests d'intrusion, laquelle de ces affirmations est exacte ?**

**A.** Tous les tests, y compris les attaques par déni de service, sont autorisés sur vos ressources

**B.** Seul AWS peut réaliser des tests de sécurité sur l'infrastructure du client

**C.** **Sur les services autorisés, le client peut tester ses propres ressources sans approbation préalable, mais les attaques par déni de service restent interdites** ✔

**D.** Une approbation préalable d'AWS est obligatoire pour chaque test, sans exception

**EXPLICATION**

**Réponse : C**

Les tests sur vos propres ressources, pour les services listés par la politique, sont possibles sans approbation. Les DoS/DDoS non autorisés restent interdits.

## Points clés à retenir

| Notion | À retenir |
|---|---|
| **Responsabilité partagée** | AWS : sécurité DU cloud (matériel, data centers, réseau, logiciel d'infrastructure). Client : sécurité DANS le cloud (données, IAM, configuration, OS invité sur EC2). |
| **Services gérés / abstraits** | Plus le service est géré (RDS, Lambda, S3), plus AWS en gère. Le client garde toujours données, accès et configuration. |
| **Contrôles** | Hérités (sécurité physique), partagés (correctifs, configuration, formation), propres au client. |
| **IAM** | Service global. Utilisateurs, groupes (sans imbrication), rôles (identifiants temporaires), politiques JSON. Refus implicite par défaut ; un Deny explicite l'emporte. |
| **Compte racine** | MFA, aucune clé d'accès, usage réservé aux tâches qui l'exigent (ex. fermer le compte) ; utiliser un utilisateur IAM au quotidien. |
| **Identifiants** | Console : mot de passe (+ MFA). CLI/SDK : clés d'accès (la clé secrète ne s'affiche qu'une fois). Applications sur EC2 : rôle IAM. |
| **AWS Organizations** | Gestion multi-comptes. Les SCP définissent un plafond de permissions, ne donnent rien, et s'appliquent aussi au root des comptes membres. |
| **Audit et conformité** | CloudTrail (qui a fait quoi), Config (état et conformité des ressources), Artifact (rapports de conformité), Trusted Advisor (recommandations). |
| **Chiffrement** | KMS (clés gérées), CloudHSM (HSM dédié), ACM (certificats TLS). Chiffrer au repos et en transit. |
| **Détection et protection** | Shield (DDoS), WAF (HTTP/couche 7), GuardDuty (menaces), Inspector (vulnérabilités), Macie (données sensibles dans S3), Secrets Manager, Cognito. |